



**Qualys received
4.9 out of 5 stars
and a 95% willingness
to recommend.**

“Our overall experience with Qualys TotalCloud has been exceptional, providing robust multi-cloud security, seamless integration, and user-friendly interface that significantly enhances our cloud security management.”

- [Gartner Peer Insights](#)



Episode 2

Rethinking Cloud Security

A Deep Dive into Cloud-Native Vulnerability Management

"Welcome back everyone! For those joining us for the first time, I'm David Greenwood, and this is Episode 2 of our cloud security series. If you missed Episode 1 where we unpacked what CNAPP really means and explored modern security best practices, don't worry - it's available on-demand on BrightTalk and rounds out what we're covering today.

"I'm joined again by Matt Campbell, one of our Solutions Architects here at Qualys, who works with our customers daily helping them navigate cloud security challenges. In Episode 1, we defined CNAPP and talked about the 'why.' Today, we're going deeper into the 'how' - specifically, the three core capabilities that make CNAPP work: vulnerability management, configuration security, and threat detection.

"Same format as last time: Drop your questions in the chat anytime and we'll address them as we go. We'll run a few polls throughout our session today to get your perspectives - it's always valuable to see what's happening across different organizations.

"We'll be covering five focused questions today, each building on the CNAPP foundation we established in Episode 1. By the end of the session, you'll understand how CWP, CSPM, and CDR work together to give you complete visibility and protection across your cloud environments. And we'll wrap up with a look at where cloud security is heading - some exciting developments in AI and automation that we see will be changing the game over the next few years.

So, really, the first question writes itself today. Why are we renaming tools, Vulnerability

Management to Cloud Workload Protection, Security Configuration or Policy Management to CSPM, just because the infrastructure platform has changed?

3 Thanks Dave and, yes, great to be here for another Cloud Security Webinar, thank you everyone for taking the time to join us to

So, those of you who joined us last month will know that I'm a little uncomfortable making too much of the split between security practice in the cloud versus your on-prem or endpoint environments. I think there's a mistaken tendency for cloud security specialists to imagine that somehow cloud security is different, or more advanced, or 'special' in some fundamental way that doesn't apply to other types of cyber security.

At a high level, good security practice shouldn't depend on your technology choices, and you should seek to apply the same security principles in all domains - whether that's cloud, on-prem, endpoints, or mobile.

There is, however, one key implementation change when moving to the cloud that DOES have an impact on how we realize our security principles, and that's the shared responsibility model.

When you run infrastructure on-premises, you're responsible for everything. The physical building security, the network hardware, the servers, the hypervisor, the operating system, the applications, the data - it's all yours to secure. Although you may be split into different teams with different responsibilities, your organisation is responsible for it all.

In the cloud, that responsibility splits. AWS, Azure, and GCP secure the underlying infrastructure - the physical data centers, the network fabric, the hypervisor layer, the foundational Platform as a Service offerings, hosted databases, storage accounts, load balancers and so on. That's 'security OF the cloud' - and it's their job, not yours. They're responsible for making sure the physical infrastructure doesn't fail, the hypervisor doesn't have vulnerabilities, the network fabric is secure and so on.

But everything you deploy ON that infrastructure - your virtual machines, if you're talking infrastructure as a service, but its also the configurations of your platform as a service tools, your IAM policies the configurations of your storage accounts or hosted databases. You're also responsible for how your data can be accessed, your storage account configurations, or the security of the applications your dev teams deliver. This is 'security IN the cloud.' The cloud provider gives you a well secured tools platform, but they won't stop you if you decide configure them insecurely, or if you run insecure workloads on them. That's your responsibility.

So this is why some new terms come in now, eventhough they have a clear ancestry in traditional tool classes, because of the :

As Dave mentioned in his introduction, today we're going to be looking more closely at 3 key cloud security tool types. There are others, we touched upon them last session and we'll mention them in passing today, but, at least for me, these 3 tools are absolutely foundational when talking cloud security.

First is Cloud Workload Protection, CWP, sometimes also called CWPP or Cloud Workload Protection Platform. This handles the workloads you deploy and run.

Our friends at Gartner define a workload as *"Specific application, service, capability, or amount of work that can be run on a cloud instance or cloud service."* So its a some code you want to **deploy** to your cloud, supported by some services, for example databases or web servers, in response to a **business need**.

So CWP exists to protect the workload, by scanning your application libraries for CVEs, monitoring your VMs for unknown processes, or scanning your container images in CI/CD. CWP's closest ancestor is traditional vulnerability scanning. If you're familiar with vulnerability scanners like Qualys VMDR or endpoint protection tools, CWP does similar things but oriented to cloud workloads that may be more ephemeral in nature than traditional application payloads and their infrastructure. Its still essentially about finding CVEs and other fixable issues in software, but "center of gravity" has moved from the server or endpoint, to the workload, regardless of where that workload may be running at any given time.

CSPM, or Cloud Security Posture Management is the second key security feature in the cloud. This assess how you've configured the cloud provider's services. Are your security groups too permissive? Is your storage publicly accessible? Do your identities have least privilege? Is MFA enforced? The cloud provider isn't going to tell you you've misconfigured their services insecurely - that's your responsibility to monitor, remembering that there are very solid business use cases for any of those more insecure configurations of your cloud. So we use CSPM to assist us with managing this complexity, its like having an automated auditor that continuously checks your cloud configuration against security best practices so you know at all times, the exact level of your exposure, and aren't caught by surprise.

Finally, CDR, or Cloud Detection and Response. This your alarm system, so you know what's actually happening in your cloud right now. Not theoretical risk, like that measured with CVSS scores or CSPM benchmarks. So we're talking suspicious identity activity, signatures of compromise like becoming out to command and control servers, lateral movement attempts, port scanning, malware detections and so on. This is analogous to an EDR tool, like CrowdStrike or Qualys EDR, but at "whole cloud" level rather than for an individual resource.

I hope its clear that while at high level, we're still trying to solve the same problems, its just that we have some different strengths and weaknesses to deal with when we apply those use cases to the cloud. A final thought here, and harking back to Episode 1 again, these capabilities tend to work best when they're used together, in a CNAPP platform, correlating the signals we get from each to gain a richer view of the security position of our cloud environment.

So you'll remember from last time how keen I am in studying breaches as part of any discussion about security practices and t

"Let me show you a perfect example where all three capabilities we're discussing today - CWP, CSPM, and CDR - could have prevented a massive ransomware attack: The Kaseya VSA breach of July 2021.

Kaseya VSA is a remote monitoring and management solution used by managed service providers to manage their clients' IT infrastructure, and it can be hosted both on prem or deployed to the cloud. In July 2021, attackers exploited a credential disclosure vulnerability, a privilege escalation vulnerability and a upload authentication vulnerability to gain access to the platform, and upload and distribute ransomware to various end customers systems.

Because many VSA customers are managed service providers who manage dozens or hundreds of downstream clients, this breach had big impact. The ransomware spread from the MSP's VSA servers to approximately 1,500 downstream businesses. The total ransom demand exceeded \$70 million.

The attack chain was pretty straight forward. First, attackers scanned the internet for exposed VSA servers.

Here's our first opportunity to block the attack. A CSPM tool would alert on the public exposure of a cloud hosted VSA instance and prompt us to question if the exposure was truly necessary.

Once they found internet-facing instances, it was trivial to download the system credentials. With those credentials, they authenticated to the VSA system, used the second vulnerability to escalate privileges and then used VSA's software deployment feature - designed to push legitimate updates - to distribute ransomware to all managed systems.

Here's another chance to block the attack. CWP would alert us to all these vulnerabilities, and they all have high base risk due to their seriousness in the kind of threat they have to VSA and adjacent systems, so we'd be prompted to upgrade VSA to remediate the vulnerabilities and close off the attack vector.

And there's a place for CDR to step in with post breach detections and alerts. It would detect the ransomware payload being moved across the network to the targeted systems.

Any of the 3 capabilities we're discussing today had a role in either blocking this breach entirely, or enabling rapid response to it.

Thanks Matt for that high level introduction, and yes, this “defence in depth” concept is one we return to again and again, and how failure in more than one of these domains is needed for nearly all the breaches we see.

So, now time for our first poll question, what do you think is the biggest issue of the 3 facing your organization today?

--- Poll Options ---

CWP - Don't have good vulnerability visibility in cloud workloads

CSPM - Don't know what's misconfigured in our cloud

CDR - Not actively monitoring for threats in real-time

We're covering all three reasonably well

Ok, while those are rolling in, I'd like to dig into the individual tool types in a bit more detail, starting with CWP. Organisations could have prevented the Kaseya breach by finding and patching those CVEs, but here's the reality most security teams face: when you scan your cloud estate, you don't get a nice clean list of 5 vulnerabilities to fix. You get 10,000 findings, with more than half of them marked 'Critical' or 'High.' Your team can maybe fix 50 per week, with the help of your developers, perhaps more, but never all of them. So how do you actually prioritize vulnerabilities properly, how do you know which vulnerabilities are exposing you to the most risk?"

Yep, its tough. I think by now the message has well and truly landed when it comes to vulnerability management at scale. You

What you should be doing is applying intelligence to direct your efforts and prioritize your patching actions towards those that are going to deliver the greatest reduction in real risk for your environment.

And here's a side note for the risk reduction goal, remember that deploying a patch is, in itself, an action that has risk. So over patching of low risk vulnerabilities may be reducing your vulnerability count, but actually increasing your aggregate risk profile.

Then, the question becomes: how should I prioritize my vulnerabilities? This is where CVSS, or Common Vulnerability Scoring System often comes into the picture. CVSS uses a deterministic set of classifications to provide a numerical risk or severity score to CVEs in the NIST National Vulnerability Database, the authoritative registry of CVEs.

In these webinars, I do like to include references where appropriate, but I didn't think I'd be referencing a random reddit user! However, I thought redditor u/FordPrefect05 summed it up so beautifully I had to quote them : 'CVSS alone will lead you to patch printers while leaving RCEs wide open on prod.' with RCEs being Remote Code Execution vulnerabilities. Too true.

The message is, "context matters". Review any vulnerability management solutions promotional material and you'll see very similar criticism of CVSS based prioritization, and I can only imagine first.org, the developers and maintainers of the CVSS standard tearing their hair out. This is not what CVSS base scores are for!

So what is CVSS? Back in 2005 first.org, or the Forum of Incident Response and Security Teams, a non profit professional organization

Today all my examples are coming from CVSS version 3.1 the most common score in use today, and the screenshots are from their official CVSS calculator.

The first thing to understand is that CVSS base scores are essentially a high water mark, the worst case evaluation of any CVE, and all of a sudden it starts to become clear why so many are high or critical.

To demonstrate that, I'm going to walk through a scoring example for a theoretical CVE.

You can already see, I've made this a bad one. Its remotely exploitable, easy to exploit, doesn't require any privilege compromise, and I don't have to get user interaction, its not a phishing attack.

Setting Scope to Changed means the attack can broaden out of the security scope of the directly impacted resource, it can escalate privileges, or move laterally etc.

Then I evaluate it against the cyber security CIA triad, that describes the 3 key attributes of an information system, what impact does this vulnerability have on a system's Confidentiality, Integrity and Availability. I'm setting High for all 3.

No surprise with all this, I have a severity 10, Critical vulnerability.

So when your basic vulnerability scanner detected this CVE, the lights would be flashing red
Immediate action is required

But this was never meant to be the end of the story. Scrolling down in the calculator, the temporal factors are shown

Yes, this is a serious issue, but what do we know about what's actually happening with this vulnerability out in the wild? Is there exploit code? Is there a fix? How sure are we the vulnerability even exists?

Well, good news for my toy vulnerability, there's no practical demonstrated exploit. Doesn't mean there isn't one, and likely the

There's no official fix, no patch released, there is a way to mitigate with a workaround, perhaps I can block a port or terminate a service. This also lowers risk, as there will be less effort put into exploit by bad actors. Finally, I'm going to say we're pretty confident the vulnerability is real, but it hasn't been fully confirmed by the vendor or another credible source. So I'll set the Report Confidence to Reasonable.

So, once we bring in the temporal factors, what's the state of this vulnerability right now? We see that our sev 10 critical, is, at least at this moment in time, not as serious as we might have been led to believe looking at the base score alone.

92
Going further in the calculator, we see the Environmental Score section.

This is an assessment of what this vulnerability really means to you, in your environment, not in some theoretical information system. I can make some re-estimates of the characteristics of the vulnerability, based on what I know about my own environment.

So, for this example, the toy vulnerability was detected in say, my staging environment, which isn't connected to the internet and is in its own isolated virtual network.

First the CIA triad:

I'm only using simulated data in my staging environment, so I don't have any real confidentiality issues, I'd prefer the data wasn't leaked because perhaps they can find out things about my application I don't want them to know, but the data itself not that important to me, so I set the Confidentiality Requirement to Low.

I'm more worried about integrity though, this is a staging environment afterall, so I want my system to be giving correct results, but its not production, so I'll set this to medium.

Availability, I can live with it being down for a bit if there's an issue with it, so I'm going to set my Availability Requirement to Low.

Then, because my staging network is not routeable from the internet, I'm changing the attack vector to adjacent, something compromised on my network can exploit it, but not beyond that, I'm protected from internet attack.

I'm also going to change the scope, there isn't anything in my staging network vulnerable to any kind of lateral movement or privilege escalation that might happen because of compromise via this CVE, say.

And there we go, my sev 10 critical – sirens blaring, code red, this is not a drill CVE, once I fully understand both the threat landscape, the temporal factors, and how the SW carrying this CVE is actually deployed in my environment, I'm down to a medium risk CVE and perhaps I should focus my attention elsewhere.

So, having understood that, how can this be operationalised at scale? In a word, automation.

This is an area that Qualys really shines in, so I'll use us an example, but in the interests of fairness, there are other tools out th

We have our own proprietary scoring and vulnerability identity engine based around Qualys IDs or QID and Qualys Detection Scores, or QDS. They are a little different to CVEs, we group related CVEs and other vulnerabilities together, you can loosely think of this as a set vulnerabilities that are fixable with a single patch.

Once grouped, we set the temporal attributes in a more comprehensive way than CVSS by bringing in more than 25 threat intel feeds plus data from our own dark web and other scanners. The Qualys Threat Research Unit also does original research and investigation of the vulnerabilities. This results in a QDS score which includes both base and sophisticated temporal factors.

Then for any asset, we can aggregate the QDS scores for vulnerabilities detected on it, and finally bring in the environmental fa

And it doesn't stop there, we can aggregate these scores across your different deployments, business units or whatever, to give you a fully automated, temporal and environmental aware risk score across your cloud. At Qualys, this works on prem also.

Again, we're not the only organisation that can automate this process for you, but we're certainly the leaders in this domain in particular and are basically known for our risk centric approach to vulnerability management.

Thanks Matt – I think its really helpful to go back to basics like that. To see that the all important contextual enrichment we've l

So that takes us to our next poll. It would really be interesting to see how our webinar participants are doing their vulnerability prioritization today.

--- Poll options ---

Nothing - we're still figuring this out

Manual processes (gut feel, experience-based triage)

CVSS base scores only

EPSS (Exploit Prediction Scoring System)

Risk-based scoring (QDS, TruRisk, or vendor-specific)

Multiple methods combined

So, while the answers are coming in, let's take a look at the results of the previous poll. Ok, some interesting responses there

So, we've talked about CWP finding and prioritising vulnerabilities in your workloads, but in nearly all the breaches we've looked at over the time we've been working together, a vulnerability isn't enough. To exploit a vulnerability it usually needs to be in place alongside a posture failure. Or perhaps a better way to look at it is; with good posture, that's good configuration, of your cloud, or any system you're securing, you can be much less concerned about vulnerabilities.

So let's talk about that in a bit more detail. What is Cloud Security Posture Management? What configuration risks is looking for?

17, exactly. As you said, pretty much all breaches we study need some element of configuration failure in order to happen. FI

So let's look at what configuration management means in the cloud. Here we have an example of a class of tool that exists not because the use case is different, but rather because of a capability we have in cloud environments we don't have, on-prem or in other environments, or at least we don't often have, the cloud provider API.

Having a master API that can control almost all aspects of your environment is a characteristic of public cloud platforms like AWS, Azure, GCP and others.

CSPM is, at heart, a rules engine that plugs into this API, that is configured with "policy as code" rules to check your cloud setups against security controls, that are then bundled into security policies.

Its main characteristics. Its:

Agentless: No need to install anything on VMs or containers, which simplifies deployment significantly.

Near Continuous: subject to API polling cycles, and event ingestion, but data is consistently flowing in for assessment.

Its findings are prioritized based on the level of risk associated with any misconfiguration to direct remediation actions. It may also support automated remediation.

It supports compliance assessment, simplifying tracking compliance and audit reporting.

In operation:

1. The system queries the cloud provider API to get a full inventory of your cloud assets and all their characteristics.
2. It processes that data with a rules engine that evaluates pass or fail on system or user-defined security controls.
3. And it groups the evaluations of those security controls into policies for reporting the level of compliance of your environment against cloud security policies.

Let me show you how critical these configuration checks are with a real-world example - and how multiple misconfigurations

In May 2020, a large cloud services provider serving nonprofits, charities, schools, and healthcare agencies suffered a devastating ransomware attack. These are organizations that depend on trust and handle sensitive personal information, such as donor identifies, student records, protected health data ,etc

Let me walk you through the cascade of configuration failures. The entry point was network exposure - services that should have been internal-only were exposed to the internet, accessible from anywhere, with the windows remote desktop protocol port 3389 wide open. This is a classic entry point and attackers scan for just this. Once identified, they bombard the port with weak passwords and compromised credentials lists.

Once attackers gained initial access, they moved laterally because of further posture failure, namely identity and access management weakness. Accounts without multi-factor authentication made credential attacks easy. Service accounts with overly broad permissions opened other lateral movement options. These credential failures gave attackers a lot of movement freedom..

Then came the data exfiltration. Storage accounts and databases lacked proper access controls. Stored data wasn't encrypted at rest, or compromised credentials had unnecessary permissions to encryption keys. The attackers extracted massive amounts of sensitive data.

The result: approximately 13,000 customer organizations compromised, rippling out to affect those organizations' own clients and donors. A \$50 million settlement with attorneys general from 49 US states. Massive reputational damage in a sector built on trust.

Here's what makes this breach so instructive: The legal settlement specifically cited failing to implement reasonable data security and failing to remediate known security gaps. These weren't sophisticated zero-day exploits. These were basic infrastructure, identity, and data protection misconfigurations sitting there, visible in the infrastructure, waiting to be exploited - exactly what CSPM continuously monitors across all these security domains.

19 So given the legal settlement in that breach specifically called out “reasonable security controls”, you may be wonderi

CSPM policies can be grouped into the four main categories shown on the slide.

Anyone who's heard me speak before about the major cyber security standards or benchmark publications knows how highly I rate them, particularly the NIST publications and CIS Benchmarks. If you're someone that seeks to understand cyber security better you owe it to yourself to read them. They are often surprisingly readable and approachable, I assure you it will not be time wasted.

Second, compliance mandates that may be legally required for your industry.

Third, cloud provider best practices. These are the recommendations directly from the platforms themselves about how to configure their tools securely.

And fourth - this is critical - your own custom policies. CSPM isn't just out-of-box checks you can't control. You can tune it to your organization's risk tolerance and requirements.

The goal is actionable security that fits your business and reduces your risk, a standard to measure your compliance against, and not just a checklist for ticking boxes.

Thanks Matt - that's really helpful to understand how CSPM works across all those different security domains. I think what really

Let's get a quick sense from the audience - how are you currently monitoring your cloud security posture? Hit the poll.

--- Poll Options ---

Manual audits (quarterly or less frequent)

CSPM tool in place

Cloud-native tools only (AWS Config, Azure Policy, etc.)

Combination of tools

We don't have good visibility

Planning to implement CSPM

And again, while those responses come in, we'll take a look at the results from our previous poll on vulnerability prioritization.

Now Matt, let's move a little further along the attack chain. We've talked about CWP finding vulnerabilities and CSPM finding misconfigurations. But what if the attackers are already inside? Despite your best efforts a system has been compromised and backdoored, or say they've got compromised credentials through phishing or social engineering? However it's happened, you're breached.

Cloud Detection and Response, is the solution, the cloud equivalent of Endpoint Detection and Response. So what is it, what problems is it solving and what do our colleagues on the session today gain in applying it?

21 I will now present a breach study that demonstrates the utility of key CDR features: The TeamTNT cryptojacking campaign that's b

Not every attack is exactly the same, but there is a general pattern.

Stage 1: Port Scanning. TeamTNT used tools like masscan to scan millions of IP addresses looking for exposed Docker daemons, APIs, SSH servers and more. This is mass reconnaissance - systematically probing the internet to find vulnerable targets.

Stage 2: Once they identify exposed services, they compromise unsecured APIs, or run brute force attacks looking to exploit weak credentials.

Stage 3: After gaining access, they deploy multiple types of malware: cryptominers to monetize the victim's compute resources, the Sliver command-and-control framework to maintain persistent access, and rootkits to hide their presence.

Stage 4: Then the Sliver C2 framework establishes persistent communication back to attacker-controlled infrastructure, with regular beaconing to receive commands and exfiltrate data.

Stage 5: Finally, lateral Movement. TeamTNT spreads across Docker and Kubernetes clusters, or other cloud hosts, using compromised credentials to move laterally. They steal cloud access keys, expanding their reach.

End result is compromised machines, mining crypto, available as staging for further attacks, and very hard to clear infestations.

Here's why this is such a perfect CDR example: There is no software vulnerability being exploited, just weak passwords and exposed services. CSPM, and as we'll see in Episode 3, KSPM, will flag some of these security weaknesses, but it doesn't tell you they are being actively exploited right now.

On the other hand, CDR would have caught this at multiple stages by continuously monitoring your cloud environment for activ

So, in the TeamTNT attack chain, here's what CDR detects at each stage:

It detects reconnaissance activity like port scanning when attackers probe your environment looking for exposed services.

It detects repeated authentication attempts, especially failed attempts followed by successful compromise. This catches credential-based attacks before they succeed or immediately after.

CDR detects the malware, cryptominers, rootkits and C2 frameworks, as they are transferred across your network with machine learning classifiers. Automated malware mutation in test environments and entropy analysis of payloads allows us build classifiers for new malware, even if signatures don't exist yet.

It watches lateral movement by looking for unusual network traffic between resources and abnormal credential use.

CDR detects persistent connections to external infrastructure, so called command and control beaconing, as it correlates outbound connections with threat intelligence about known malicious IPs and domains.

Finally, CDR detects cloud credentials being accessed and alerts on those signals.

This is why you need CDR: it watches for active attack behaviors that CWP and CSPM simply can't see. It's continuous monitoring focused on detecting active attacks as they happen, not pre-breach scanning for potential weaknesses."

As I've done a few times in today's presentation, I'd like to return to Episode 1 briefly, just to mention that a CNAPP platform brings

It comes back to that key concept the “context matters”.

Yes, all these tools are useful on their own, yes the individual alerts are providing prioritized and actionable intelligence. But when brought together in a single platform, the additional context means the individual alerts can be correlated, aiming for that single, prioritized view of risk that we see as vital to securing complex cyber infrastructure in organizations of all scales.

24 6DR is definitely a big part of the puzzle for overall security. Its not enough just to try to prevent access, you need tooling and c

So, throwing it open to the audience once again, how are you approaching this post breach problem?

--- Poll Options ---

Native cloud tools only (GuardDuty, Defender, etc.)

SIEM with cloud log integration

Cloud-native CNAPP with CDR

We're not actively monitoring for threats yet

Multiple tools, but hard to correlate findings

As always, lets review the results from our poll question on CSPM.

Ok, we covered some really important ground today, with a survey of three of the most important tools or tool classes in cloud security, but we both know things aren't standing still out there. If we raise our eyes from the here and now and look in the future a little, what do you see as the main challenges to come in cyber security?

I've list a few of the torrent of new AI enabled security attacks, proof of concept and actual, being announced pretty much daily right now

So, last year, Google Big Sleep an AI vulnerability research tool made the first pure AI vulnerability detection in public SW, finding a security flaw that had escaped human security researchers in the widely used SQLite database tool.

Earlier this year, RapidPen, an AI pen testing tool demonstrated some really quite impressive capabilities, being able to autonomously run so called IP address to shell attacks, showing how it could identify and exploit vulnerabilities in SSH, RDP and similar to gain access to target systems autonomously, probing and making different attacks depending on the responses of the target system.

Finally, HexStrike-AI this is the big one as far as I'm concerned. HexStrike-AI was developed as a red team tool, but now its the hands of real attackers. What's interesting about HexStrike-AI is that its agentic. So its not just a single tool, but rather a suite of agents that can be deployed to automate all the stages of an attack, from recon , to exploit to payload delivery, all without human intervention, and with its own capabilities to move and adjust as the defensive systems attempt to block it. Its making deploying very sophisticated attacks at scale much simpler and massively lowering the bar to entry for bad actors.

The rapid and automated nature of attacks facilitated by HexStrike-AI challenges traditional defense mechanisms, such as signature-based detection and manual patching processes. Organizations must adapt by implementing adaptive detection systems, integrating AI-driven defense tools, and shortening patch cycles to mitigate the risks posed by such advanced threats.

At Qualys we're responding to this new threat class by deploying our own AI tooling to allow your organization to have a chance

At Black Hat U.S. this year, we unveiled the Agentic AI-Powered Risk Operations Center - a marketplace of Cyber Risk AI Agents that deliver autonomous risk management.

Agentic AI Roc provides a suite of pre-built AI agents for specific security tasks, such as monitoring your external attack surface, doing risk prioritization, or autonomously remediating via patch deployment or configuration changes. You'll also be able to build your own agents for specific security tasks.

The shift to agentic AI is happening faster than most people realize. The ISC2 survey of 432 cyber security professionals this year found that 30% of respondents are already using some kind of AI in their tooling and a further 42% had plans to do so. Only 10% of respondents had no plans to look at AI tooling.

The efficiency gains are real. Palo Alto Networks, in a blog post in March this year, measured the time saved through automation and AI in their own, admittedly large, SOC as equivalent to 65 full-time employees. When you're processing hundreds or thousands of security alerts per day, AI can be an efficiency game changer, and as we saw in the previous slide, it's the only way you're going to be able to move as fast as your attackers.

That's the shift that Qualys and other tools in the space are making: from tools that detect and alert, to systems that autonomously manage cyber risk at scale and at speed. It means you, as the cyber professionals will be able to transition from tactical to strategic in your outlook. It's the next stage in the evolution of the automation we're already bringing to cyber security, and it's going to happen way faster than you think.

Download the GigaOm Radar for Container Security

See Why Qualys Was Named a
Leader and Outperformer



Thanks massively to everyone for joining us today – as always its been a pleasure to discuss cloud security with you and hopefully shed some more light on the alphabet soup that is cloud security. Key takeaways for me are to not necessarily focus in one area of cloud security but to achieve defence in depth by covering all bases, ensure that your risks are correctly prioritized and don't skip on that behavioural analysis! Now we've run through our workload protection, our posture management and our threat detection its time to turn to one of the more hardcore cloud deployment methods out there – containerisation.

Join us again on the 13th of November where we'll be taking an in depth look into the word of containers, best practises and how to avoid getting caught out. See you then!